

NORTHSTAR FINANCIAL GROUP

Business Continuity & Disaster Recovery Plan

Business Impact Analysis, Recovery Strategy, Continuity Procedures, and Improvement Roadmap

PORTFOLIO SIMULATION - NO REAL CLIENT DATA

Northstar Financial Group is a fictional organization used to demonstrate business continuity, disaster recovery, risk analysis, and executive communication skills.

Prepared by Ryan Bryant | Cybersecurity Analyst Candidate

Version 1.0 | September 2026

Document Control

Control	Value
Document owner	Northstar BC/DR Program - simulated
Prepared by	Ryan Bryant
Version	1.0
Date	September 2026
Purpose	Define Northstar's target-state business continuity and disaster recovery requirements, recovery priorities, activation procedures, and corrective actions.
Intended audience	Executive leadership, IT, Security, HR, Finance, Legal/Compliance, and recovery stakeholders
Classification	Portfolio Simulation / No Real Client Data
Review cycle	At least annually and after material technology, vendor, facility, or business-process changes

Contents

1. Executive Summary
2. Scope, Objectives, and Planning Assumptions
3. Governance and Roles
4. Business Impact Analysis
5. Recovery Priorities and Dependencies
6. Recovery Strategy and Target Architecture
7. Plan Activation and Continuity Procedures
8. Recovery and Reconstitution Procedures
9. Communications and Third-Party Coordination
10. Security During Recovery
11. Testing, Training, and Maintenance
12. Findings and Corrective Actions
13. 90-Day Improvement Roadmap
14. Tabletop Exercise Summary
- Appendix A. Recovery Quick Reference
- Appendix B. Reference Frameworks

1. Executive Summary

Northstar Financial Group (NFG) is a fictional 75-person financial-services organization used for a portfolio simulation. This plan translates the organization's prior risk and IAM assessments into a business continuity and disaster recovery program focused on resilience, recoverability, and decision-making during major disruption.

EXECUTIVE CONCLUSION

Northstar can continue limited operations through cloud services and manual workarounds, but its current recovery posture contains material single points of failure. The highest-priority gaps are headquarters-concentrated backups, backup frequency that cannot demonstrate several 1-hour RPOs, untested restoration capability, headquarters-dependent remote access, identity recovery concentration, and overreliance on a single cloud backup provider.

Primary Outcomes

- Established recovery objectives for 10 critical business and technology services, including time-dependent objectives for Payroll, VPN, and Security/Logging.
- Defined recovery tiers that prioritize identity, backup, and core network services before dependent business applications.
- Designed a target recovery architecture that separates production, local recovery, off-site backup, and immutable/isolated recovery copies.
- Defined a parallel recovery-and-security model so disaster restoration can continue while suspicious activity is investigated.
- Completed a four-inject tabletop exercise that exposed an RPO failure, privileged-access investigation requirements, and cloud-provider concentration risk.
- Created an eight-finding corrective-action register and a 90-day implementation roadmap.

2. Scope, Objectives, and Planning Assumptions

2.1 Scope

This plan covers business continuity and disaster recovery for the following services: Active Directory / Entra ID, Microsoft 365, Customer CRM, Finance File Repository, Payroll SaaS, HRIS, VPN / Remote Access, Backup Infrastructure, Accounts Payable / Payment System, and Security / Logging Platform.

2.2 Objectives

- Protect life and employee safety before technology recovery.
- Maintain essential business functions through alternate work methods when systems are unavailable.
- Restore critical services in an order that respects technical dependencies and business impact.
- Meet approved RTO and RPO targets or formally record and remediate recovery gaps.
- Preserve security visibility and evidence during recovery.
- Avoid creating a new single point of failure while fixing an existing one.

2.3 Planning Assumptions

- Northstar operates a headquarters location with a mix of internal infrastructure and cloud/SaaS services.
- The current local backup NAS is located at headquarters, remains connected to production, and has not undergone a full restoration test.

- The current backup process is nightly unless otherwise stated; no offline or immutable copy is assumed in the current state.
- Microsoft 365, CRM, Payroll, and HRIS are cloud-hosted; service restoration may depend on provider capabilities and escalation processes.
- The target state introduces geographically independent remote access, off-site backup, isolated/immutable recovery copies, and more resilient identity services.
- RTO is treated as the maximum acceptable time to restore a service; RPO is the maximum acceptable data/configuration loss measured backward from the disruption.

3. Governance and Roles

Role	Primary responsibility
Executive Sponsor / CEO	Declares or authorizes major continuity posture, approves exceptional spending, and receives business-impact briefings.
BC/DR Coordinator	Activates the plan, coordinates workstreams, tracks RTO/RPO deadlines, maintains the situation report, and escalates missed objectives.
IT Recovery Lead	Restores identity, network, server, backup, endpoint, and application infrastructure in dependency order.
Security Lead	Maintains monitoring, preserves evidence, validates privileged activity, and determines whether security findings require a recovery activity to pause.
HR / Personnel Accountability	Accounts for staff, issues employee instructions, and maintains authoritative Joiner/Mover/Leaver and emergency contact information.
Finance Continuity Lead	Prioritizes financial obligations, manages temporary finance procedures, and validates reconciliation after data recovery.
Legal / Compliance / Communications	Coordinates contractual, regulatory, vendor, customer, insurer, and public communications based on confirmed impact.
Vendor Liaison	Maintains escalation contacts, service tickets, contractual SLAs, and provider status for SaaS, remote access, and backup services.

4. Business Impact Analysis

The BIA establishes business impact, maximum acceptable outage, data-loss tolerance, and scenario-dependent criticality. These objectives are business requirements; technical capabilities must be tested against them.

ID	Service	Impact	RTO	RPO	Key dependencies	Continuity rationale
BCDR-01	Active Directory / Entra ID	Critical	2 hrs	1 hr	Authentication, identity, admin recovery	Critical dependency for access to multiple services and recovery activities.
BCDR-02	Microsoft 365	High	5 hrs	1 hr	Entra ID, internet, Microsoft SaaS	Phones and alternate communications provide short-term continuity, but prolonged loss severely disrupts collaboration.
BCDR-03	Customer CRM	Critical	2 hrs	1 hr	Entra ID, internet, SaaS provider	Manual notes support short outages; longer loss delays customer service and creates reconciliation workload.
BCDR-04	Finance File Repository	Critical	2 hrs	1 hr	AD, internal network, storage	Authoritative finance records are required for accounting, contractual, payment, and executive decisions.
BCDR-05	Payroll SaaS	High / Critical at payroll	12 hrs / 4 hrs peak	24 hrs	Entra ID, internet, SaaS provider	Time-dependent impact; urgency increases around processing and pay deadlines.
BCDR-06	HRIS	High	24 hrs	1 hr	Entra ID, internet, SaaS provider	Manual HR procedures are viable briefly; prolonged loss affects lifecycle, payroll, and recordkeeping.
BCDR-07	VPN / Remote Access	Moderate / High	24 hrs normal	1 hr config	Network edge, identity, internet	Becomes high priority when headquarters is unavailable; normal cloud SaaS may remain directly reachable.

ID	Service	Impact	RTO	RPO	Key dependencies	Continuity rationale
BCDR-08	Backup Infrastructure	Critical	1 hr	24 hrs config	Storage, network, admin authentication	Recovery-enabling service; business-data RPOs remain governed by each protected workload.
BCDR-09	Accounts Payable / Payment	High / Critical at deadlines	5 hrs	1 hr	Identity, network/SaaS, bank/vendor data	Manual intake is possible briefly; longer loss risks missed obligations and duplicate/reconciliation errors.
BCDR-10	Security / Logging Platform	High / Critical during attack	1 hr	1 hr	Network, log sources, admin access	Loss reduces security visibility and may become critical during malicious activity or recovery operations.

BIA GAP IDENTIFIED

Several services require a 1-hour RPO while the current recovery process is based on nightly backups. The current capability therefore cannot demonstrate compliance with the approved recovery points for all critical workloads.

5. Recovery Priorities and Dependencies

5.1 Recovery Order for Headquarters Infrastructure Loss

Priority	System	Rationale
1	Active Directory / Entra ID	Restore authentication and administrative access needed by dependent systems.
2	Backup Infrastructure	Make validated recovery data and catalogs available for damaged systems.
3	Security / Logging Platform	Restore visibility so the recovery can be monitored for malicious or abnormal activity.
4	Finance File Repository	Restore authoritative financial data for contractual, accounting, and payment decisions.
5	VPN / Remote Access	Restore broader remote productivity after recovery-enabling and higher-impact systems are stable.

PARALLEL RECOVERY PRINCIPLE

Priority order establishes business importance and dependency. It does not require strictly sequential work. Identity, backup validation, security monitoring, and provider escalation should proceed in parallel where dependencies and staffing allow.

5.2 Recovery Tiers

Tier	Services	Purpose
Tier 0 - Recovery Enablers	Active Directory / Entra ID; backup infrastructure; core network/DNS/connectivity	Required to restore or administer other services.
Tier 1 - Critical Recovery & Security	Security/logging; Customer CRM; Finance File Repository	Restore quickly after Tier 0 dependencies are available.
Tier 2 - High-Priority Business	Microsoft 365; Accounts Payable; Payroll during normal periods	Can tolerate several hours with controlled workarounds.
Tier 3 - Workaround Available	HRIS; VPN under normal headquarters conditions	Manual or alternate procedures support short-term continuity.

Dynamic criticality: Payroll moves toward Tier 1 during payroll-processing windows. VPN moves toward Tier 1 when the headquarters facility is inaccessible. Security/Logging becomes Critical during malicious activity.

6. Recovery Strategy and Target Architecture

6.1 Remote Access Resilience

- Establish a geographically independent cloud-hosted or secondary remote-access path that does not rely on headquarters infrastructure.
- Require MFA, emergency administrative access, provider escalation contacts, configuration backups, and periodic failover testing.
- Retain organizational visibility into authentication, configuration, and connection logs; do not outsource accountability with the service.

6.2 Backup and Data Recovery

- Retain a local recovery copy for rapid restoration where practical.
- Maintain an encrypted off-site copy in a separate failure domain.
- Maintain an additional immutable, offline, or otherwise isolated recovery copy that cannot be destroyed by the same credentials or platform used for production.
- Protect critical workloads with recovery points frequent enough to meet their individual RPOs; 1-hour RPO systems require at least hourly-capable recovery points or equivalent replication/snapshot capability.
- Perform periodic full backups as part of retention strategy, but do not rely on a single monthly full + nightly incremental schedule for workloads with 1-hour RPOs.
- Perform restoration tests and record achieved RTO/RPO results.

6.3 Identity Resilience

- Maintain Entra ID as a cloud identity layer and reduce unnecessary dependency on headquarters-only directory services.
- Where traditional Active Directory remains required, maintain redundant domain/DNS capabilities in a separate failure domain and protect directory recovery data independently.
- Maintain emergency cloud administrative identities with strong controls and documented break-glass procedures.
- Test identity recovery, DNS dependencies, role/group restoration, and post-recovery privilege integrity.

6.4 Resilience Design Principle

TARGET-STATE PRINCIPLE

No single physical location, provider, credential set, or administrative plane should be able to eliminate both production capability and all recovery options.

7. Plan Activation and Continuity Procedures

7.1 Activation Criteria

- Headquarters becomes inaccessible or unsafe.
- A Tier 0 or Tier 1 service is expected to exceed its RTO without coordinated recovery.
- Production and primary recovery infrastructure are simultaneously unavailable.
- A major cyber incident requires broad restoration or alternate operations.
- A critical SaaS/provider outage materially affects business operations.

7.2 First Five Actions

1. Account for personnel and secure the physical site. Coordinate with emergency services and prohibit entry to unsafe facilities.
2. Activate the BC/DR plan and continuity team. Establish an incident/continuity lead, alternate communications, and a situation log.
3. Establish alternate operations and begin Tier 0 recovery. Direct staff to approved remote-work procedures and validate cloud identity and remote-access capability.
4. Restore security visibility and critical business services. Operate IT recovery and Security investigation workstreams in parallel.
5. Manage business and external communications. Notify affected customers, vendors, insurers, and contractual partners based on confirmed impact and requirements.

7.3 Manual Continuity Controls

- Use controlled manual forms for short-term HR, Finance, and Accounts Payable activity when authoritative systems are unavailable.
- Assign unique transaction/reference numbers to temporary records to prevent duplicate entry.
- Store continuity records only in approved secure locations/channels.
- Require reconciliation and secondary validation when the authoritative system returns.
- Suspend high-impact financial decisions when authoritative records are unavailable unless an approved emergency process exists.

8. Recovery and Reconstitution Procedures

8.1 Recovery Validation

- Restore from the most recent validated recovery point available.
- Confirm data/configuration timestamp against the approved RPO.
- Record any RPO miss; technical restoration does not equal successful recovery if the business objective was not met.
- Validate application functionality, authentication, security controls, and business-owner access before declaring service restored.
- Reconcile temporary/manual records and require secondary review for high-risk financial or HR data.

8.2 Reconstitution

- Do not return to the primary site until Facilities/emergency authorities declare it safe.
- Validate restored systems in the temporary environment before migration back to normal infrastructure.
- Preserve evidence and change records from the recovery period.
- Remove temporary emergency privileges, firewall rules, workarounds, and alternate routes after validation.
- Conduct a post-incident review and update the BIA, recovery procedures, vendor requirements, and training based on lessons learned.

9. Communications and Third-Party Coordination

Audience	Communication content
Employees	Safety instructions, work location, approved communication channels, temporary procedures, status updates.
Customers	Confirmed service impacts, expected delays, alternate contact

Audience	Communication content
	options, and restoration updates when appropriate.
Vendors / partners	Contractual impacts, payment/service delays, escalation contacts, and workaround requirements.
Cloud/SaaS providers	Incident ticket, priority escalation, service status, RTO dependency, evidence/log availability.
Insurer / legal / regulators	Notifications only when triggered by policy, contract, law, or confirmed incident facts.
Executive leadership	RTO/RPO status, business impact, decisions required, risk acceptance, and forecast to recovery.

COMMUNICATION RULE

Do not speculate that an outage is malicious, a breach occurred, or data was compromised until evidence supports that conclusion. Communicate known impact, actions, and next update time.

10. Security During Recovery

- Continue disaster recovery unless security evidence shows a specific recovery action would spread, preserve, or reintroduce compromise.
- Preserve authentication, VPN, firewall, endpoint, backup, and SIEM telemetry relevant to the disruption.
- Prioritize privileged-account review during recovery; validate successful sign-ins, MFA events, session creation, role changes, and configuration changes.
- Use separate privileged identities, MFA, time-bound access where available, and detailed administrative logging.
- Pause a specific restoration activity if evidence shows compromised administrator credentials, contaminated recovery data, malicious persistence on the recovery system, or unauthorized changes to backup/security controls.
- Expand account/log review beyond privileged identities when evidence indicates broader compromise.

RECOVERY-SECURITY PRINCIPLE

Business recovery and security investigation operate in parallel unless continuing a specific recovery action would increase the likelihood or impact of compromise.

11. Testing, Training, and Maintenance

- Conduct at least annual tabletop exercises and repeat after major architecture, facility, vendor, or business-process changes.
- Perform scheduled restoration tests for Tier 0 and Tier 1 systems and record achieved recovery times and recovery points.
- Test alternate remote access and provider escalation paths without relying on headquarters.
- Test employee accountability and alternate communications.
- Test Finance and HR reconciliation procedures using sample continuity records.

- Review emergency contacts, vendor contracts, recovery owners, and access credentials at least quarterly.
- Update the plan after every exercise, material incident, or failed recovery test.

12. Findings and Corrective Actions

ID	Finding	Risk	Business consequence	Corrective action	Owner
BCDR-R01	Backup frequency vs. 1-hour RPOs	Critical	Nightly protection can leave nearly a workday of changes unrecoverable.	Use hourly-capable recovery/replication for 1-hour RPO workloads; verify restore timestamps.	IT / Business Owners
BCDR-R02	Backup and production share one failure domain	Critical	A site-level event can affect production and the local recovery copy together.	Keep encrypted off-site plus immutable/offline copies in separate failure domains.	IT
BCDR-R03	Remote access depends on headquarters	High	Loss of the building can remove both physical and remote access to internal resources.	Deploy geographically independent alternate remote access and test failover.	IT
BCDR-R04	Identity recovery is concentrated	Critical	HQ-only AD/DNS dependencies can block recovery of dependent systems.	Reduce HQ-only dependency; maintain separated identity/DNS recovery and emergency cloud admin access.	IT / IAM
BCDR-R05	Restoration capability is unproven	Critical	Successful backup jobs do not prove usable restoration or RTO/RPO achievement.	Run full and partial restore tests; measure RTO/RPO and track defects.	IT / BC-DR Coordinator
BCDR-R06	Finance off-site copy misses RPO	Critical	Exercise copy was 6 hours stale against a 1-hour Finance RPO.	Increase Finance recovery frequency; formalize reconciliation and secondary validation.	Finance / IT
BCDR-R07	Security during recovery is not formalized	High	Privileged recovery may occur without clear monitoring, evidence, or pause criteria.	Add a security workstream, privileged validation, evidence preservation, and pause criteria.	Security / IT
BCDR-R08	Cloud backup provider concentration	High	A provider portal outage can delay restores while headquarters is unavailable.	Maintain an independent secondary recovery path and test provider-loss scenarios.	IT / Vendor Management

13. 90-Day Improvement Roadmap

Window	Objective	Key actions
0-30 days	Immediate resilience	Approve BIA/RTO/RPO targets; establish alternate remote-access design; secure off-site backup; define emergency contacts; create restore-test schedule; document security-during-recovery SOP.
31-60 days	Technical implementation	Implement hourly-capable recovery for 1-hour RPO workloads; separate backup credentials; create immutable/offline copy; establish identity/DNS redundancy; configure independent log retention where practical.
61-90 days	Validation and governance	Run Tier 0/Tier 1 restore tests; test remote-access failover; conduct follow-up tabletop; validate vendor outage procedures; reconcile achieved RTO/RPO with business targets; update contracts and plan.

Success Measures

- 100% of Tier 0/Tier 1 systems have documented owners, dependencies, tested restore procedures, and measured recovery results.
- No critical workload relies on only one location/provider/credential plane for all recovery copies.
- Recovery-point frequency meets or exceeds approved RPOs for protected workloads.
- Alternate remote access can be activated without headquarters infrastructure.
- Tabletop and technical restore exercises produce tracked corrective actions with owners and due dates.

14. Tabletop Exercise Summary

Scenario: an electrical fire makes headquarters inaccessible for at least three weeks while cloud services remain available. The exercise then introduces stale off-site Finance data, suspicious administrator sign-in attempts during recovery, and an outage at the cloud backup provider.

Exercise event	Decision / outcome
Inject 1 - Site loss	Prioritized safety, personnel accountability, plan activation, alternate work, Tier 0 recovery, security visibility, and controlled external communications.
Inject 2 - Finance RPO miss	Restored the best available off-site copy but did not falsely declare the RPO met; initiated secure reconstruction and secondary validation of missing records.
Inject 3 - Suspicious admin sign-ins	Continued recovery while opening a parallel security investigation; prioritized privileged identities and preserved evidence rather than

Exercise event	Decision / outcome
	stopping all restoration.
Inject 4 - Backup-provider outage	Recognized new cloud concentration risk and required an independent secondary recovery copy while the organization remained displaced.

EXERCISE ASSESSMENT

Capable with material gaps. Northstar demonstrated sound decision-making around safety, recovery prioritization, manual continuity, and parallel security investigation, but the exercise exposed material deficiencies in backup frequency, recovery separation, restoration testing, and third-party concentration.

Appendix A. Recovery Quick Reference

Time / phase	Primary actions
0-15 min	Safety/accountability; declare BC/DR event; establish incident lead and alternate communications.
15-60 min	Validate cloud identity; establish alternate remote access; validate off-site backups; restore/maintain security visibility.
1-2 hrs	Recover identity dependencies; restore backup control plane; restore/validate Finance/CRM priority paths as needed.
2-5 hrs	Restore Accounts Payable/M365 as impacted; begin reconciliation; communicate verified customer/vendor impact.
5-24 hrs	Restore remaining high/moderate services; continue monitoring; reconcile temporary records; track missed objectives.
Reconstitution	Validate business owner acceptance; remove temporary privileges/workarounds; preserve evidence; return to normal site only when safe; conduct post-incident review.

Appendix B. Reference Frameworks

Reference	How used	Link
NIST SP 800-34 Rev. 1 - Contingency Planning Guide for Federal Information Systems	Used as the primary structural reference for contingency planning, BIA, recovery strategy, plan development, testing/training/exercises, and plan maintenance.	https://doi.org/10.6028/NIST.SP.800-34r1
Ready.gov - Business Continuity Plan template	Used as a practical business-continuity reference for BIA, RTO/RPO, recovery strategies, alternate worksites, IT recovery, communications, and team responsibilities.	https://www.ready.gov/sites/default/files/2020-03/business-continuity-plan.pdf
CISA #StopRansomware Guide	Used to inform recommendations for offline/encrypted backups, regular restoration testing, immutable/isolated recovery, and multi-provider resilience considerations.	https://www.cisa.gov/stopransomware/ransomware-guide

Portfolio note: This document demonstrates analytical and planning skills. It is not a certification of compliance with NIST, CISA, financial-services regulations, or any contractual standard.